

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1404

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyse how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

Commands:

1. `theHarvester -d tesla.com -b all`
2. `theHarvester --version`

Purpose : This command performs an OSINT scan on the target domain tesla.com using the Rapid DNS search engine. It collects publicly available information such as email addresses, subdomains, hosts, and IP addresses.

Findings :

- **Emails:** 0 (No public emails found)
- **Hosts/Subdomains:** 668
- **IP Addresses:** 53
- **Interesting URLs:** 19

Risk Analysis

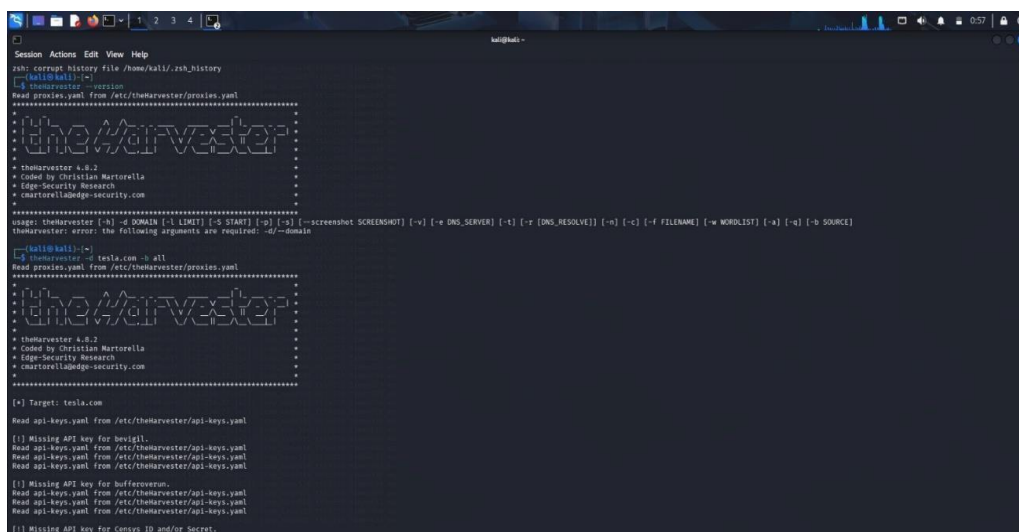
- Public hosts and URLs reveal Tesla's external infrastructure.
- Authentication portals may be targeted for credential harvesting.
- Public service names can be used in spear-phishing campaigns.
- Infrastructure details support reconnaissance and impersonation attacks.

Recommendations

1. Conduct regular OSINT assessments to identify exposed information.
2. Enable Multi-Factor Authentication (MFA).
3. Train employees to recognize phishing attacks.
4. Reduce unnecessary exposure of public subdomains.
5. Continuously monitor public-facing assets and DNS records.

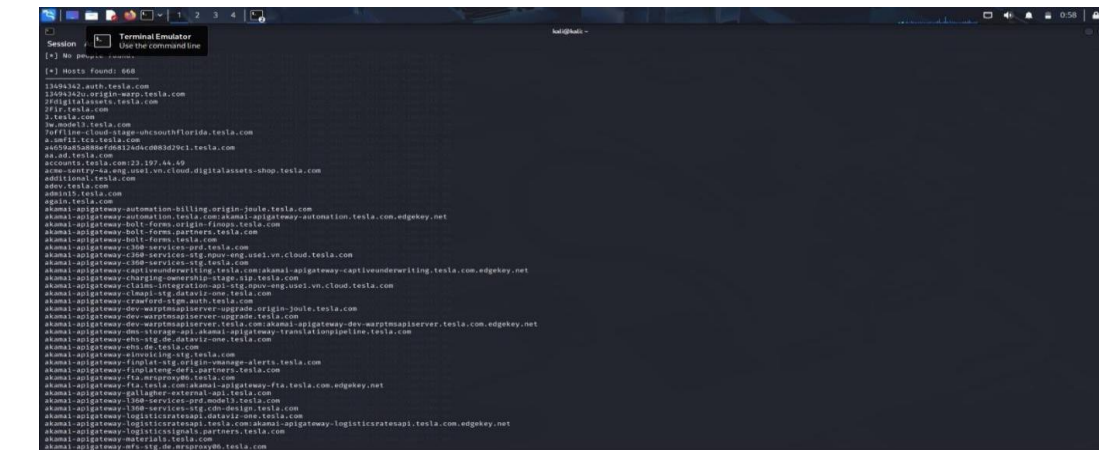
Conclusion :

The OSINT assessment successfully identified public hosts/subdomains related to tesla.com. No public email addresses or IP addresses were discovered. The collected information demonstrates how attackers can gather infrastructure details during the reconnaissance phase and highlights the importance of minimizing public information exposure and implementing strong security controls.



```
Session Actions Edit View Help
ssh: corrupt history file /home/kali/.ssh_history
kali@kali:~$ theHarvester -d tesla.com -b all
Read proxies.yaml from /etc/theHarvester/proxies.yaml
=====
theHarvester
=====
• theHarvester 4.2.2
• Coded by Christian Martorella
• Edge-Security Research
• cmartorell@edge-security.com
=====
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-v] [-w DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q] [-b SOURCE]
theHarvester: error: the following arguments are required: -d/--domain

kali@kali:~$ theHarvester -d tesla.com -b all
Read proxies.yaml from /etc/theHarvester/proxies.yaml
=====
theHarvester
=====
• theHarvester 4.2.2
• Coded by Christian Martorella
• Edge-Security Research
• cmartorell@edge-security.com
=====
[+] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for bvgill.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for huffavetum.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for Censys ID and/or Secret.
```



2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.(20 Mark).

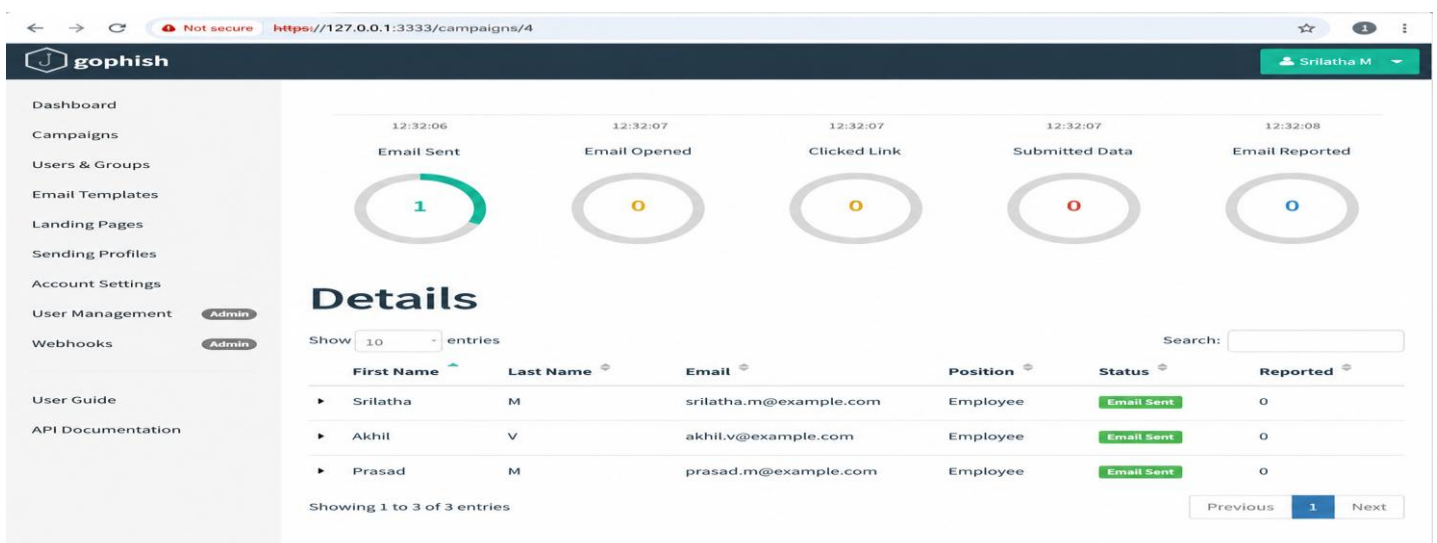
Procedure :

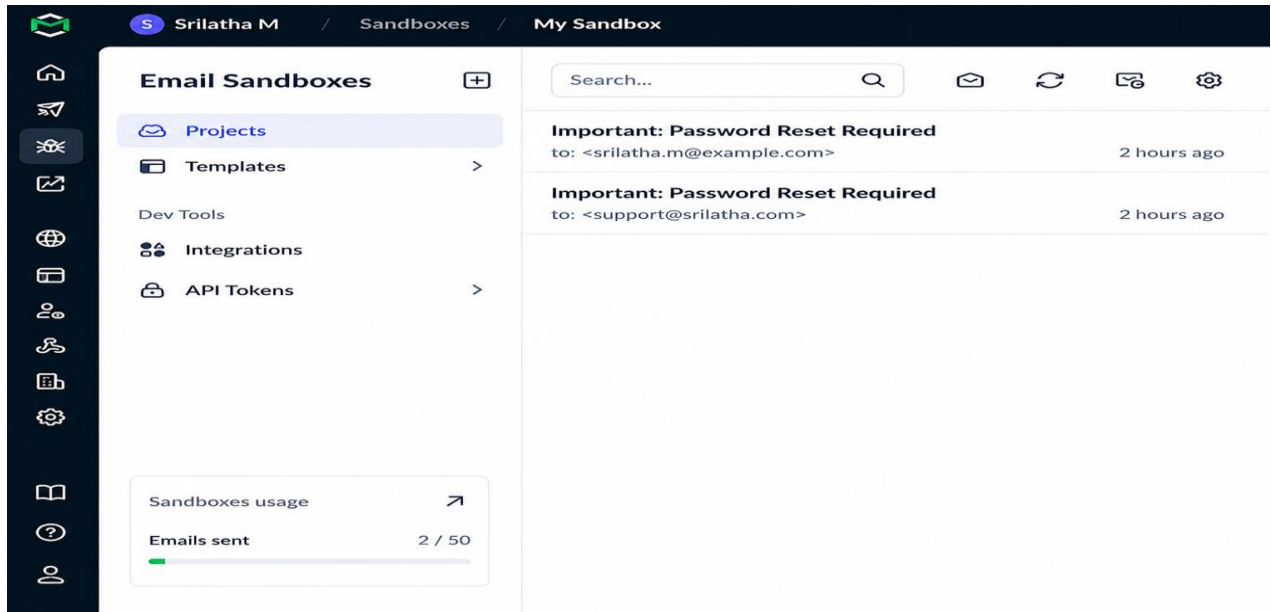
1. Created Email Template.
2. Created Landing Page.
3. Configured Mailtrap SMTP.
4. Created User Group.
5. Created Campaign.
6. Send phishing emails.
7. Viewed campaign statistics.

Metrics	Result
Target Users	3
Email Sent	1
Delivery rate	33.3%

Email Security Controls :

- Enable Spam Filtering.
- Use Email Gateways.
- Configure SPF (Sender Policy Framework).
- Configure DKIM (DomainKeys Identified Mail).
- Configure DMARC (Domain-based Message Authentication, Reporting, and Conformance).
- Block dangerous attachments.
- Scan email attachments using antivirus software.
- Enable URL filtering.





3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.(10 Marks)

Commands :

1. `sudo nmap -A scanme.nmap.org`

Observation :

- The host is alive.
- HTTP (80) is open.
- SSH (22) is open.
- SIP ports 5060 and 5061 are open.
- Operating system information identified.

Security Recommendations :

- Keep all software updated.
- Enable firewall protection.
- Use strong authentication mechanisms.
- Perform periodic vulnerability assessments.

```
kali@kali:~$ sudo nmap -sV 45.33.32.156
Starting Nmap 7.90 ( https://nmap.org ) at 2025-08-25 06:49 -0400
Nmap scan report for icann-nmap.org (45.33.32.156)
Host is up (0.0025s latency).
Other addresses for icann-nmap.org (not scanned): 2600::b81::f83c:91ff:fe18:1b2f
Host shown: 983 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  sshd         OpenSSH 8.9p1 Ubuntu-0ubuntu0.2
|_ssh-hostkey: F80K: Script execution failed (use -d to debug)
53/tcp    closed domain
80/tcp    open  http         Apache/2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 ((Ubuntu))
82/tcp    closed mit-ml-dev
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
993/tcp   closed imap3
3389/tcp  closed ms-wbt-server
5002/tcp  closed rfb
5006/tcp  open  sip?
5061/tcp  open  sip-tls?
5080/tcp  closed http-proxy
5081/tcp  closed blackice-iccap
5082/tcp  closed unknown
Device type: VoIP adapter/bridge/general purpose
Running (JUST GUESSED): AT&T embedded (90%), Oracle Virtualbox (80%), Slirp (80%), QEMU (80%)
OS CPE: cpe:/o:oracle/virtualbox:openjdk_8:slirp:qemu:qemu
Aggressive OS guesses: AT&T BOM210 voice gateway (90%), Oracle Virtualbox Slirp NAT bridge (80%), QEMU user mode network gateway (80%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
  hop RTT        Host
  0  2.76 ms  scann-nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 123.74 seconds
kali@kali:~$
```

Code of Conduct:

I M.Devi Srilatha (192525236) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Srilatha

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.